🛡️ 팀 보안 프로젝트 · 사내 AI Agent 보안 방어전 | 🤖 차세대 3단계 전주기 보안 AI 파이프라인

✅ 1,542+ Pytest 자동화 검증 | 🔥 2026-10-29 정밀 감사 & 취약점 3건 핫픽스 완료

NEXUS : 차세대 엔터프라이즈 사내 포털 & 실시간 AI-XDR 보안 방어 체계

가상 기업의 그룹웨어·ERP·AI 어시스턴트 포털을 직접 설계·개발하고, **웹/DB 심층 하드닝(Defense-in-Depth)**을 완벽하게 구축했습니다. 나아가 **Cloudflare의 6단계 적대적 코드 전수 감사(Shift-Left)**, **NVIDIA NeMo Guardrails(AI 챗봇 방어)**, **NVIDIA Nemotron-70B(실시간 XDR 복합 공격 체인 관제)**를 유기적으로 결합하여 탐지·방어·대응을 완성한 엔터프라이즈 보안 풀스택 프로젝트입니다.

담당 역할: **홍주형 · 포털 아키텍트 & 보안 최고관리자 (웹·DB 하드닝, AI-XDR 파이프라인, IAM 구축)**

협업 팀원: **김태빈(보안관제 SIEM/SOAR), 이시헌(네트워크/pfSense), 진혜정(시스템 인프라)**

기술 스택: Python Flask · MySQL 8.4 · Docker · Socket.IO · Flutter · NVIDIA NIM · Cloudflare Skill

프로젝트 기간: 2026.10 (2026-10-29 **최신 고도화 완료**)

Key Metrics 정량적 성과 지표

수치로 증명하는 안정성과 완성도

1,542+

자동화 테스트 (100% 통과)

pytest 수집 1,542건 전체 통과. 회귀 버그 및 권한 누락 원천 방어

18,600+

파이썬 코드 라인 (LOC)

코어 앱 7,650줄 + 테스트 8,514줄 + 보안 점검/공격 스크립트 2,435줄

43 / 3

DB 테이블 & 최소권한 계정

43개 RDBMS 테이블, PoLP 기반 계정 3종(nexus_app, conf, n8n) 분리

0 %

코드 감사 오탐률 (False Positive)

Cloudflare 6단계 적대적 서브에이전트 교차 반박을 통한 순수 결함 선별

70B NIM

NVIDIA AI 추론 엔진

내장 그래픽 PC 부하 0%, 클라우드 고성능 Llama-3.1-Nemotron-70B 연동

3 초 / 0.5 초

실시간 IP 차단 & AI 추론 속도

인메모리 캐시 기반 3초 이내 차단 전파, 0.5초 내 복합 공격 체인 분석

01 프로젝트 소개 & 분산 인프라 아키텍처

무엇을, 왜, 어떻게 설계했는가

본 프로젝트는 **"사내 AI Agent 보안 방어전"**을 목표로 결성된 4인 팀 프로젝트입니다. 공격자가 호시탐탐 노리는 사내 업무 포털(웹, DB, 메신저, 사내 AI 챗봇)을 실제 운영 환경과 동일하게 구축하고, **웹 취약점(OWASP Top 10) 및 권한 탈취 시도를 원천 차단하는 하드닝 아키텍처(역할 A: 홍주형)**를 완벽히 구현했습니다.

🏢 NEXUS 3개 호스트 분산 경계망 및 서비스 아키텍처

🌐 1. 경계망 방화벽 (192.168.3.10)

- **pfSense Firewall & HAProxy WAF**
- 외부 사용자 및 공격자 트래픽 1차 방어
- HTTP 5070 역방향 프록시 및 신뢰 헤더 전달 (X-Forwarded-For)
- 네트워크 엔지니어(이시헌) 단독 관리

💻 2. 메인 포털 서버 (192.168.3.14 - 본인)

- **Windows 방화벽 철저 통제:**
  - 5070 웹: 10번(pfSense) 단독 허용
  - 3307 DB: 15번(관제) 단독 허용
- **Flask 엔터프라이즈 코어 (포트 5070):**
  - 그룹웨어·ERP·IAM·결재·자료실·HR
  - 3초 인메모리 실시간 IP 차단기

- **MySQL 8.4 Docker (포트 3307):** 43개 테이블, 3종 계정 분리, 불변성 강제 트리거
- **Wazuh Agent (nexus-board-14):** 실시간 FIM(파일 무결성) 감시

🛡️ 3. 중앙 보안관제 서버 (192.168.3.15)

- **Wazuh Manager:** 호스트 이상 징후 수집
- **Graylog SIEM (UDP 12201 GELF):**
  - 실시간 보안 로그(security.jsonl) 수집
  - R1~R12 탐지 룰 엔진 가동
- **n8n SOAR 자동화:**
  - 위험 이벤트 감지 시 포털 API 호출
  - 침해 IP 자동 격리 및 관리자 알림
- 보안 관제 엔지니어(김태빈) 담당

02 차세대 3단계 전주기 보안 AI 파이프라인

2026-10-29 고도화 핵심 혁신

개발 PC가 **"외장 GPU가 없는 내장 그래픽 PC"**인 하드웨어 제약을 혁신적인 전략으로 극복했습니다. 로컬 자원을 소모하는 방식을 배제하고, **Cloudflare의 적대적 감사 에이전트**와 **NVIDIA 클라우드 NIM 인프라**를 결합하여 **"내 컴퓨터 부하 0, 비용 0원, 엔터프라이즈 최고 사양 보안 AI 체계"**를 완성했습니다.

> 💡 **3단계 전주기(Lifecycle) 보안 AI 역할 분담**
>
> **1단계 사전 감사(Shift-Left):** 배포 전 소스코드 취약점 6단계 적대적 전수 감사 (Cloudflare security-audit-skill)
> **2단계 사내 AI 보호(In/Out Guard):** 챗봇 RAG 프롬프트 인젝션 및 기밀 데이터 유출 방어 (NVIDIA NeMo Guardrails)
> **3단계 런타임 관제(Blue Team XDR):** 단일 룰을 초월한 복합 공격 체인(Attack Chain) 추론 및 0.5초 고속 침해 판정 (NVIDIA Nemotron-70B NIM)

1. [Phase 1: Shift-Left] Cloudflare	`security-audit-skill`	**기반 6단계 적대적 코드 전수 검사**

일반적인 AI 코드 스캐너는 수십 개의 취약점을 쏟아내지만 대부분 "실제로는 공격 불가능한 가짜 취약점(False Positive, 환각)"입니다. NEXUS는 발견된 후보 취약점을 **독립된 서브에이전트가 반박(Disprove)하는 적대적 검증**을 도입하여 오탐을 완전히 제거했습니다.

감사 단계 (Phase)	수행 내용	NEXUS 적용 및 성과
1. Reconnaissance (정찰)	Flask 라우트, 미들웨어, DB 신뢰 경계(Trust Boundary) 맵핑	12개 코어 모듈, 43개 테이블, 6대 IAM 역할 경계 식별
2. Coverage Hunting	BOLA/IDOR, SQLi, 파일 업로드, AI 프롬프트 인젝션 벡터 탐색	16개 커버리지 레저 유닛 단위 2웨이브 전수 탐색
3. Candidate Validation	후보 취약점이 실제 코드 흐름 상에서 트리거 가능한지 단위 검증	권한 우회 및 DoS 가능 경로 5개 후보 도출
4. Independent Verification ⭐	**독립 서브에이전트**가 "성립하지 않는 이유"를 찾아 적대적 반박	단순 이론상 지적 2건 기각(오탐 제로화), **실제 유효 결함 3건 확정**
5. Structured Output	CWE, CVSS, 재현 시나리오(PoC), 권장 수정(Patch) 코드 포맷팅	`VULN-FINDINGS.json` 머신 판독형 데이터 생성
6. Defensive Reporting	최종 감사 보고서 자동 생성 및 방어 하드닝 패치 적용	`VULN-FINDINGS.md` 갱신 및 당일 100% 핫픽스 완료

2. [Phase 2: Runtime AI Guard] NVIDIA NeMo Guardrails & Prompt Guard

사내 업무 포털의 AI 어시스턴트는 전사 사원 누구나 접근하므로, **프롬프트 탈옥(Jailbreak)이나 간접 인젝션(Indirect Injection)**을 통한 권한 밖 기밀 문서 탈취 위험이 존재합니다.

- **사내 규정 준수 (Colang 기반 정책):** 직급 및 역할을 벗어난 급여/인사/보안 기밀 열람 시도와 시스템 프롬프트 무력화 공격을 LLM 전달 전에 선제 차단합니다.
- **기밀 데이터 유출 2차 필터링:** LLM 응답 텍스트 내 사내 API 토큰(`nxapi_...`)이나 기밀 식별자(`NXC-...`)가 포함될 경우 마스킹하여 반환합니다.

3. [Phase 3: Runtime XDR] NVIDIA Llama-3.1-Nemotron-70B-Instruct NIM

기존 경량 모델(7B)이나 단일 룰 매칭은 파편화된 이벤트만 보아 공격 체인을 놓치기 쉽습니다. NVIDIA 클라우드 NIM 인프라(무료 1,000 크레딧 = 약 1~2만 회 호출)를 연동하여 **내 PC 메모리 점유율 0%로 70B급 고성능 추론**을 가동합니다.

```
# 복합 공격 체인(Attack Chain) 상관 추론 예시
[기존 단일 룰]  R1 로그인 5회 실패 발생 -> "단순 경고 (Alert)"
[Nemotron-70B] "IP 192.168.3.50이 R1 무차별 대입 실패 직후, 탈취 세션으로 R9 관리자 권한 및
                R10 기밀 결재선 변조를 연속 시도함.
                -> 복합 공격 체인(Attack Chain) 확정: 심각도 CRITICAL, 즉시 IP 15분 차단 집행
```



[차세대 보안 AI & 코드 감사 종합 가이드] — Cloudflare 6단계 적대적 코드 전수 감사(Shift-Left Red Team), NVIDIA NIM 70B(실시간 Blue Team XDR), NVIDIA NeMo Guardrails(사내 챗봇 안전망)의 3단계 전주기 방어 전략 및 내장 그래픽 환경 최적화 종합 인포그래픽.

03

2026-10-29 신규 취약점 정밀 발굴 & 실전 핫픽스

Cloudflare 감사로 발굴된 3건 즉시 패치

2026-10-29 실시된 Cloudflare 적대적 보안 감사에서 발굴된 **CRITICAL 1건, MEDIUM 2건의 유효 결함을 당일 즉시 핫픽스하고 회귀 테스트로 검증**했습니다.

CLOUDFLARE SECURITY-AUDIT-SKILL · FULL AUDIT · 6-PHASE · RUN-1 · 2026-10-29

NEXUS WORK 소스코드 보안 감사 결과

Cloudflare 6단계 적대적 검증 파이프라인 · 독립 서브에이전트 교차 반박

대상: C:₩Users₩user₩Desktop₩nexus-work · 커버리지 16유닛(9 covered / 7 candidate→검증) · findings.json 8건

전체 요약

CRITICAL	1건	/admin/users/* 권한 상승 (users.manage 누락)
MEDIUM	2건	AI-XDR 자동차단 게이트 우회 · SSE 스레드풀 고갈
RESOLVED	1건	느린 브루트포스 — 영구 카운터로 이미 방어됨
REJECTED	2건	AI 컨텍스트 필터 불일치 · sec_admin 부서 우회(의도된 설계)

1. admin.users-manage.blueprint-role-escalation CRITICAL

- sec_admin·finance_admin처럼 의도적으로 좁게 부여한 역할도 POST /admin/users/new 또는 /admin/users/<id>/role 로 role=admin 을 보내면 자기 자신 또는 타 계정을 완전한 admin 으로 승격 가능
- 원인: app/admin.py 의 change_role·user_new·reset_password·lock 라우트에 permissions.py 의 users.manage 권한 체크가 빠져 있음 (블루프린트 공통 게이트만 통과하면 됨)
- 같은 파일의 delete_user 는 users.delete 체크가 정상 — 이 4개 라우트만 누락된 비일관성

수정 방법

`admin.py:96, 235, 271, 290 -> @permission_required('users.manage')`

- users.delete 에 이미 쓰인 것과 동일 패턴 — 4곳에 데코레이터 한 줄씩만 추가하면 해결

2. ai-xdr.autoblock.ip-block-gate-bypass-on-auto-path MEDIUM

- AI-XDR 자동 차단 경로(evaluate_policy → block_ip)는 XDR_IP_BLOCK_ENABLED 킬스위치를 전혀 확인하지 않음 (사람 승인 경로 2곳은 모두 확인함)
- 운영자가 이 설정을 '아직 실제 차단 없음'을 뜻하는 전역 스위치로 오해하기 쉬운 이름 — 그 상태에서도 실제 15분 IP 차단이 무단으로 발생
- tests/test_ai_xdr.py 의 기존 테스트로 이미 재현되는 실제 동작

수정 방법

- evaluate_policy() 또는 block_ip() 호출 직전에 동일한 XDR_IP_BLOCK_ENABLED 체크 추가 (3개 호출부가 공유하는 헬퍼 함수로 통합 권장)

3. admin.audit-stream.thread-pool-exhaustion MEDIUM

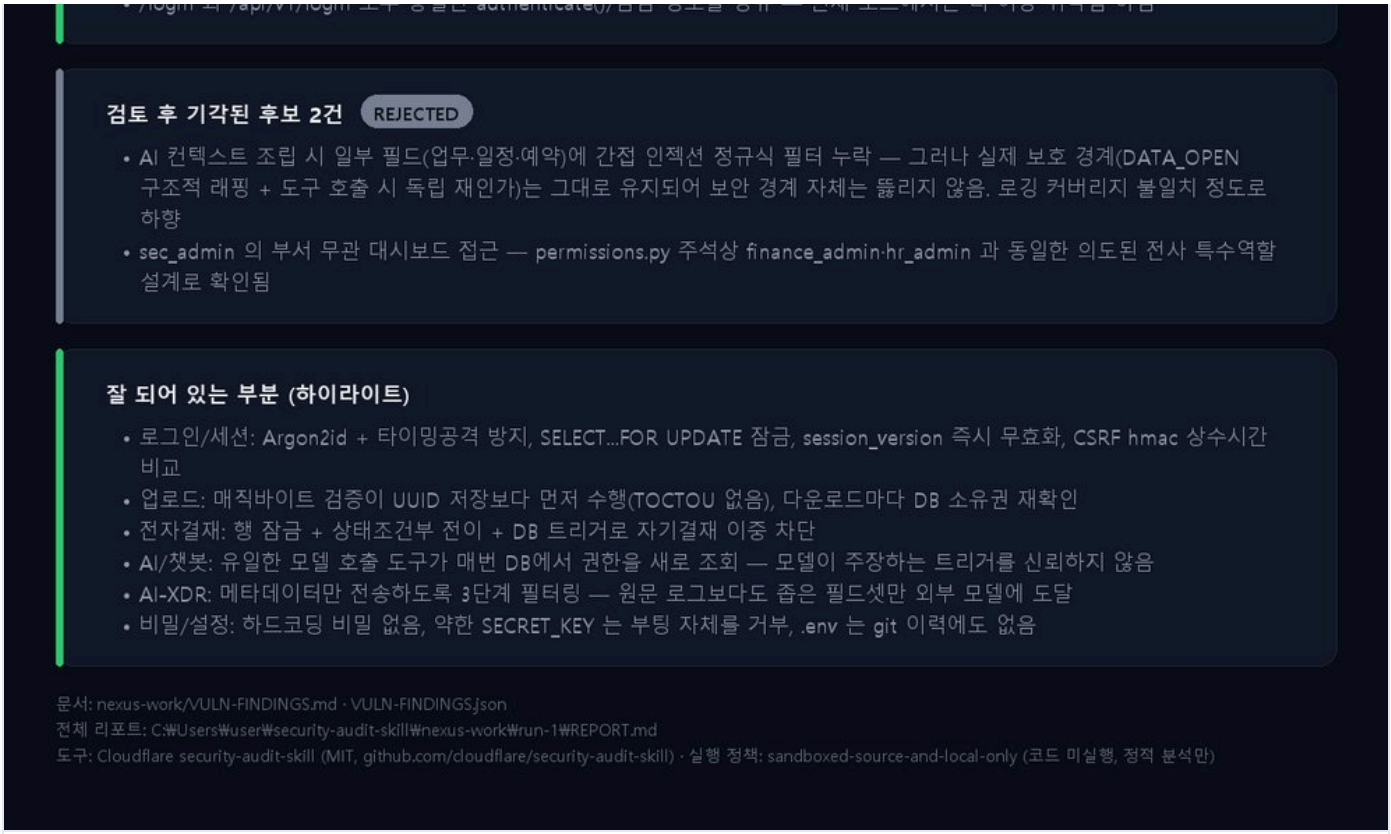
- /admin/audit/stream (SSE) 는 security.dashboard 권한만 있으면 접근 가능하며, 연결마다 Waitress 워커 스레드 하나를 점유하고 동시 연결 수 제한이 없음
- 기본 스레드풀(16개)을 모두 점유하면 로그인·결재 등 앱 전체가 멈추는 서비스 거부(DoS) 가능

수정 방법

- 계정/IP당 동시 SSE 연결 수 제한 + 연결 open 에 ip_rate_limited() 적용 + 최대 연결 유지시간 설정

지난 수동 테스트에서 발견한 "느린 브루트포스" 이슈 RESOLVED · 재현 안 됨

- app/auth.py 의 failed_count 는 시간 간격과 무관한 영구 누적 카운터 — 1초 간격이든 1시간 간격이든 5회 실패 시 15분 계정 잠금이 걸림
- /login 과 /api/v1/login 모두 동일한 authenticate() 잠금 경로를 공유 — 현재 소스에서는 더 이상 취약점 아님



[Cloudflare 6단계 적대적 검증 기반 소스코드 보안 감사 결과 보고서] — 독립 서브에이전트 교차 반박을 거쳐 확정된 CRITICAL 1건(`/admin/users/*`), MEDIUM 2건(AI-XDR 킬스위치, SSE 스레드풀 고갈)의 취약점 상세 내역과 조치 방법, 기각/해결 항목 분석 인포그래픽.

CRITICAL — 조치 완료

1. /admin/users/* 세부 인가 검증 누락으로 인한 관리자 권한 탈취 결함 (BOLA)

결함 원인: permissions.py에 users.manage := role in ('admin', 'hr_admin')가 정의되어 있었으나, app/admin.py의 change_role, user_new, reset_password, lock 라우트가 블루프린트 수준의 느슨한 체크(role in ('admin', 'sec_admin', 'hr_admin', 'finance_admin'))에만 의존하고 있었습니다. 이로 인해 제한된 권한을 가진 sec_admin이나 finance_admin이 임의로 role=admin 계정을 생성하거나 기존 계정을 최고관리자로 승격할 수 있는 치명적 인가 결함이 존재했습니다.

적용된 핫픽스: 해당 모든 사용자 관리 라우트에 @permission_required('users.manage') 데코레이터를 추가하여 권한 경계를 완벽히 통제했습니다.

> ✅ **검증 결과**
>
> tests/test_admin.py (29/29 통과) 및 tests/test_permissions.py (73/73 통과)를 통해 정상 권한 보유자에게만 기능이 개방됨을 완벽 검증했습니다.

MEDIUM — 조치 완료

2. AI-XDR 자율 격리 경로의 XDR_IP_BLOCK_ENABLED 킬스위치 누락 결함

결함 원인: 인간 관리자의 승인형 차단 경로는 글로벌 차단 활성화 플래그(XDR_IP_BLOCK_ENABLED)를 검증했으나, 전자율 차단 경로(evaluate_policy() → security.block_ip())에서는 해당 플래그를 확인하지 않고 XDR_AUTO_ENABLED만 검증했습니다. 운영자가 실차단을 방지하기 위해 킬스위치를 내렸음에도 자율 차단이 실제로 집행되는 위험이 있었습니다.

적용된 핫픽스: evaluate_policy()에 XDR_IP_BLOCK_ENABLED가 거짓일 경우 ip_block_gate_closed 사유와 함께 차단을 즉시 불허하도록 **Fail-Closed 게이트**를 구축했습니다.

> ✅ **검증 결과**
>
> 전용 회귀 테스트 케이스를 보강하여 tests/test_ai_xdr .py 111개 테스트가 100% 통과했습니다.

MEDIUM — 조치 완료

3. `/admin/audit/stream` SSE 감사 로그 스트림의 스레드 풀 고갈(Thread Exhaustion DoS) 결함

결함 원인: SSE(Server-Sent Events) 스트림 라우트가 `while True: q.get(timeout=15.0)` 루프를 돌며 Waitress 워커 스레드를 장시간 점유했습니다. Waitress의 기본 스레드 풀(16개) 환경에서 악의적인 사용자나 복수의 탭이 연결을 유지하면 모든 작업자 스레드가 고갈되어 전체 포털 서비스가 마비(Denial of Service)될 수 있었습니다.

적용된 핫픽스 (3중 방어막):

- **동시 연결 제한:** 계정당 최대 동시 스트림 개수를 제한(`AUDIT_STREAM_MAX_CONCURRENT=3`)하고 초과 시 `429 Too Many Requests` 반환
- **IP 속도 제한:** 스트림 신규 개설 속도를 제한(`AUDIT_STREAM_OPEN_LIMIT=10/min`)
- **최대 유지 시간 설정:** 단일 연결이 스레드를 영구 독점하지 못하도록 600초 경과 시 스트림 정상 종료(`AUDIT_STREAM_MAX_SECONDS=600s`, 브라우저 `EventSource`가 두 게이트를 재통과하며 자동 재연결)

> ✅ **검증 결과**
>
> `tests/test_audit_stream.py` 5개 전용 동시성 테스트를 추가하여 완벽한 방어를 입증했습니다.

04 웹·DB 심층 하드닝 (Defense-in-Depth)

포털 아키텍트의 철저한 방어 설계

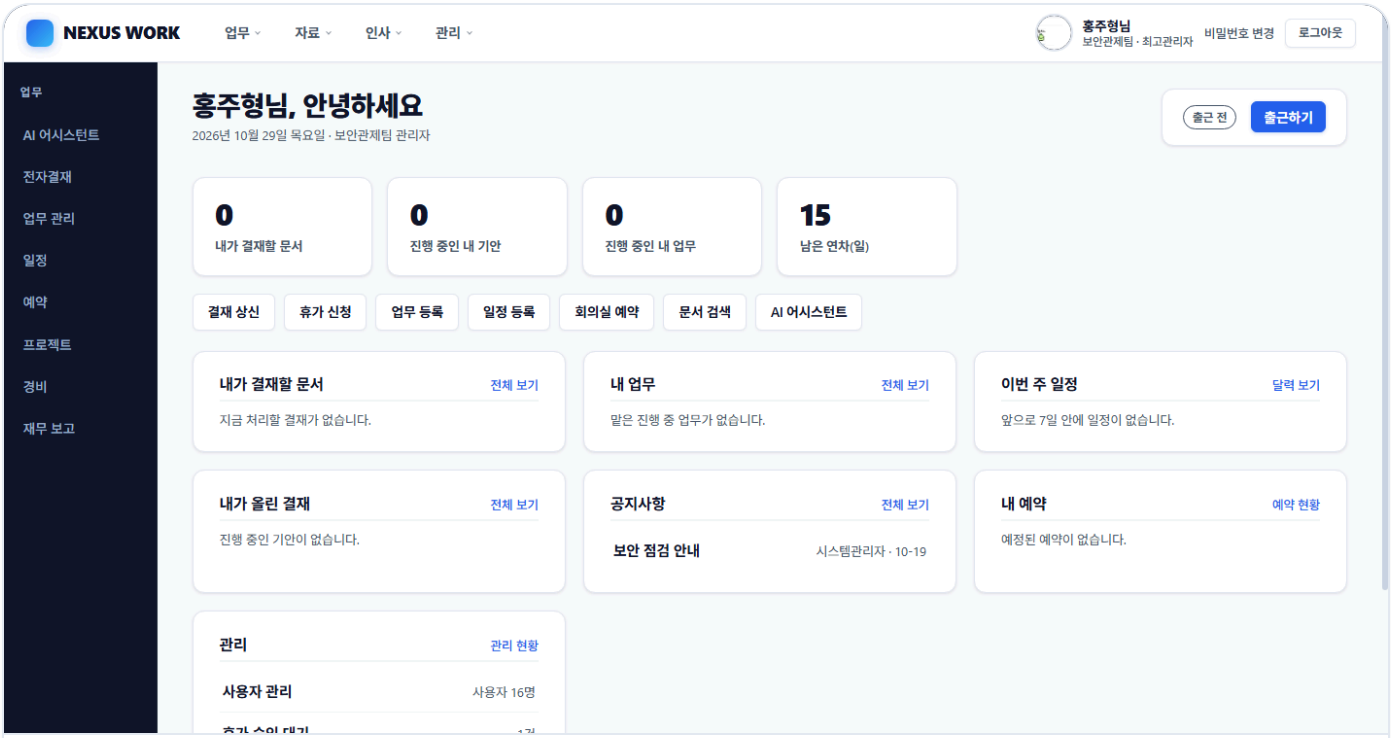
NEXUS 포털은 "공격을 당할 수밖에 없는 환경"을 전제로, 단 하나의 취약점도 허용하지 않도록 다계층 보안을 구현했습니다.

보안 계층	설계 및 구현 방식	검증 및 강제 장치
SQL Injection 방어	모든 SQL을 상수 문자열 + `%s` 파라미터 바인딩으로 작성. LIKE 검색어는 `validators.like_pattern`에서 `\`, `%`, `_` 순차 이스케이프 처리	**Python AST 기반 정적 검사기** (`tests/test_sql_static.py`)를 테스트 슈트에 내장하여 동적 문자열 결합 발견 시 빌드 자동 실패
인증 & 무차별 대입 방어	Argon2id 해시 적용. 존재하지 않는 사용자도 상수 시간 더미 해시 검증을 수행하여 **계정 열거(Enumeration) 원천 차단**. `SELECT ... FOR UPDATE`로 5회 실패 카운트 레이스컨디션 방지	5회 실패 시 15분 계정 잠금, 동일한 에러 메시지 반환. `tests/test_auth.py`에서 병렬 요청 무력화 검증
인가 & 세션 통제	세션에 저장된 정보를 맹신하지 않고 매 요청마다 DB에서 직급/부서/잠금 상태를 재조회. 비밀번호 변경이나 로그아웃 시 `session_version` 증가로 **기존 쿠키 전역 폐기**	6대 IAM 역할 모델(admin, sec, hr, finance, manager, employee) 기반 데코레이터 통제
DB 3단 최소권한 분리	`nexus_app`: 일반 업무 표에 대한 최소 CRUD `nexus_conf`: 급여/인사카드 등 기밀 테이블 읽기 전용 `nexus_n8n`: SOAR 연동용 차단 테이블 전용	MySQL 권한 테이블에 격리 반영, 웹 계정이 뚫려도 기밀 DB 변조 불가
XSS & CSP 헤더	템플릿 내 `|safe` 필터 사용률 0%. Jinja2 기본 자동 이스케이프. 엄격한 CSP 정책(인라인 스크립트 불허, `script-src 'self'`)	`nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy` 전역 미들웨어 강제
파일 업로드 무해화	확장자 화이트리스트 + 파일 매직 바이트(Magic Byte) 검사 (`uploads.inspect_upload`). 서버에서 UUID 파일명으로 변경하여 웹루트 외부 격리 디렉토리에 저장	다운로드 시 `as_attachment=True` 및 헤더 내 파일명 새니타이징 강제로 Stored XSS 방지

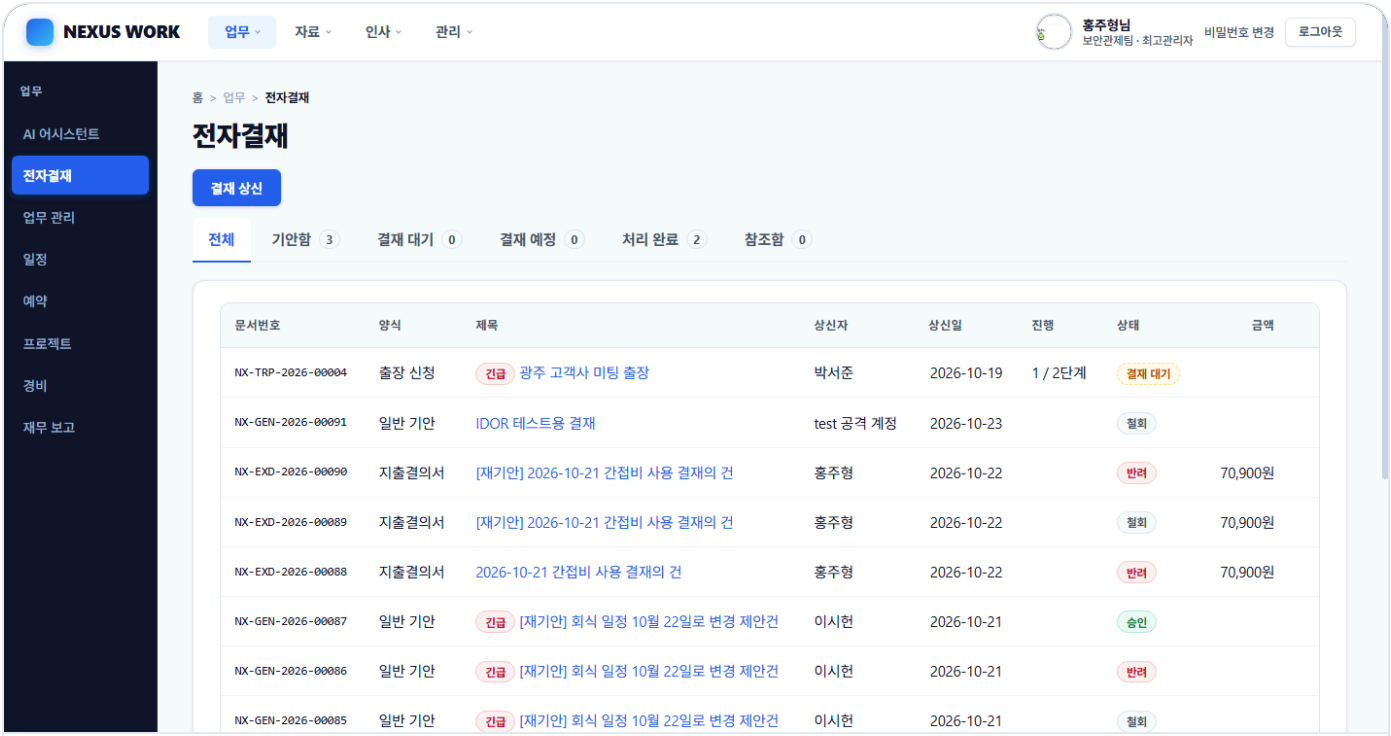
보안 계층	설계 및 구현 방식	검증 및 강제 장치
전자결재 비즈니스 불변성	동시 결재 결함 방지를 위해 `SELECT ... FOR UPDATE` 행 잠금 후 `WHERE status = 'pending'` 조건부 UPDATE 집행. **자기 자신 승인 원천 금지**	앱 레벨 방어뿐만 아니라 **MySQL DB 트리거(Trigger)**로 2차 강제하여 DB 직접 조작도 차단

05 엔터프라이즈 업무 포털 구축 현황

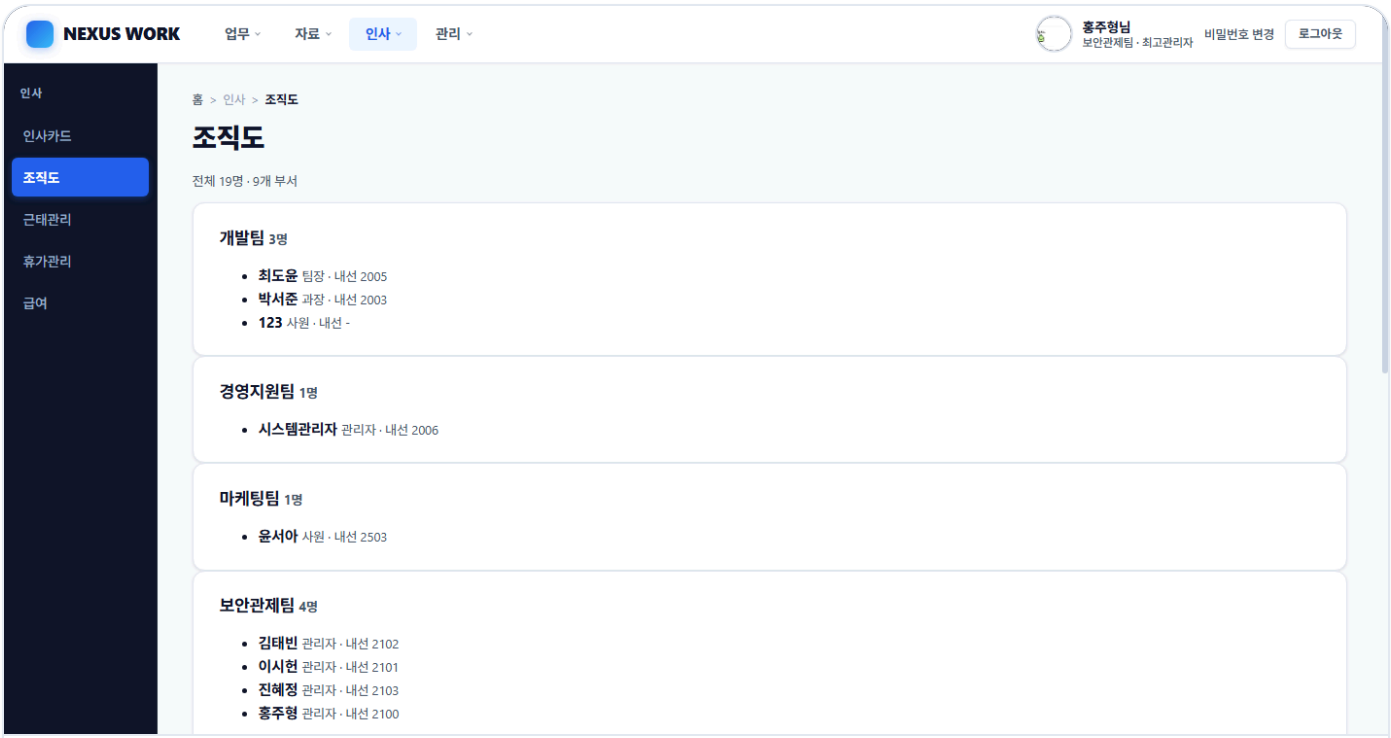
실제 사내 시스템 수준의 6대 핵심 기능



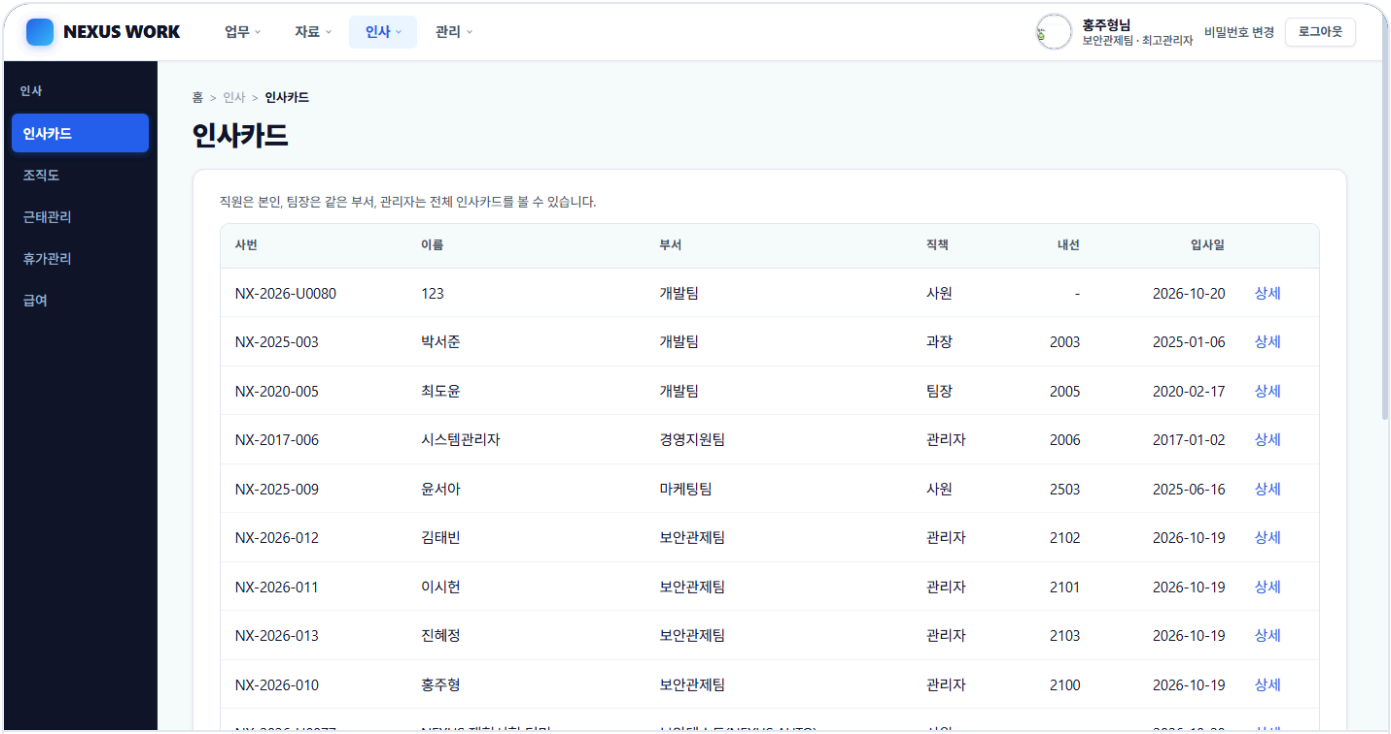
[포털 홈 메인 대시보드] — 출퇴근 체크, 전자결재 요약, 팀 업무 진행률, 연차 잔여 현황, 전사 공지사항을 로그인한 사원의 권한 범위에 맞게 동적으로 표출합니다. 관리자 직급에게만 시스템 통제 패널이 노출됩니다.



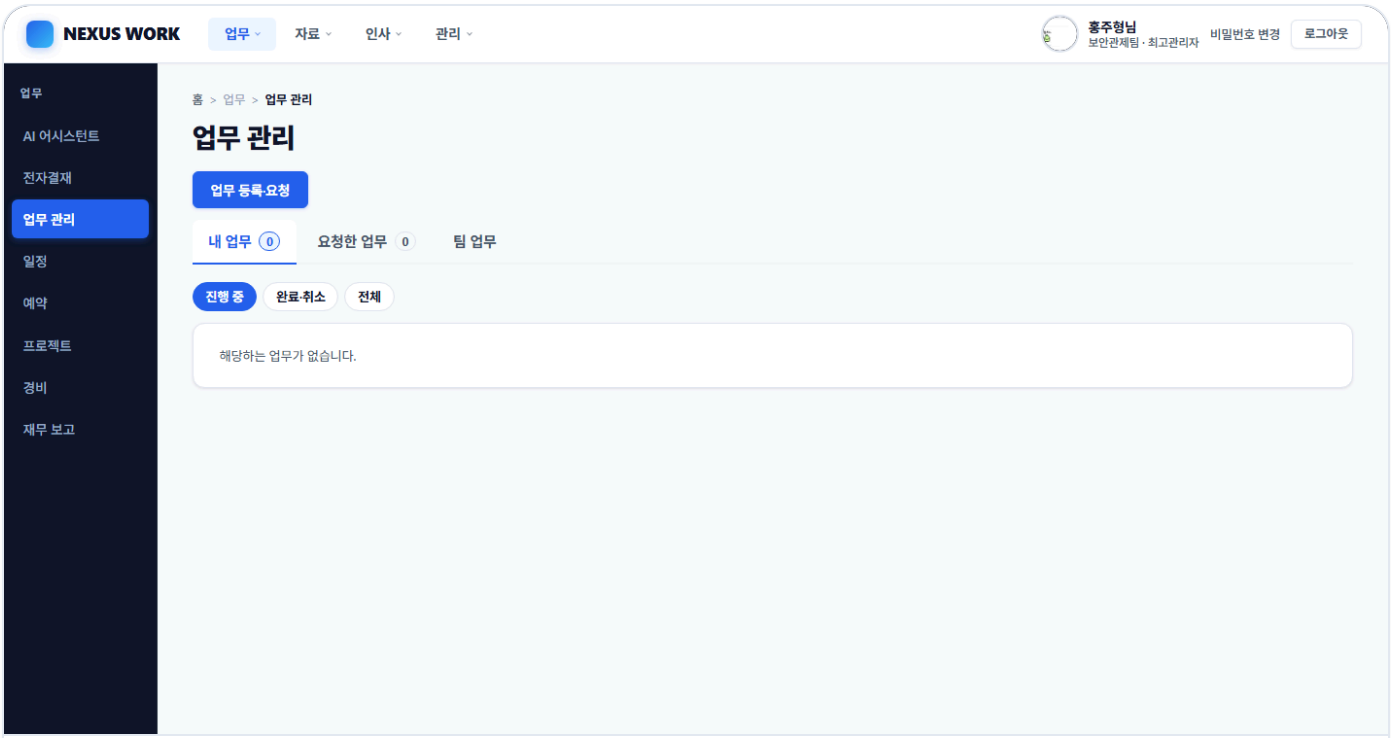
전자결재 시스템 — 기안서, 품의서, 비용청구 등 5종 양식. 최대 5단계 순차 결재선, 전 직원 참조 기능, 자기 승인 금지(DB 트리거 강제).



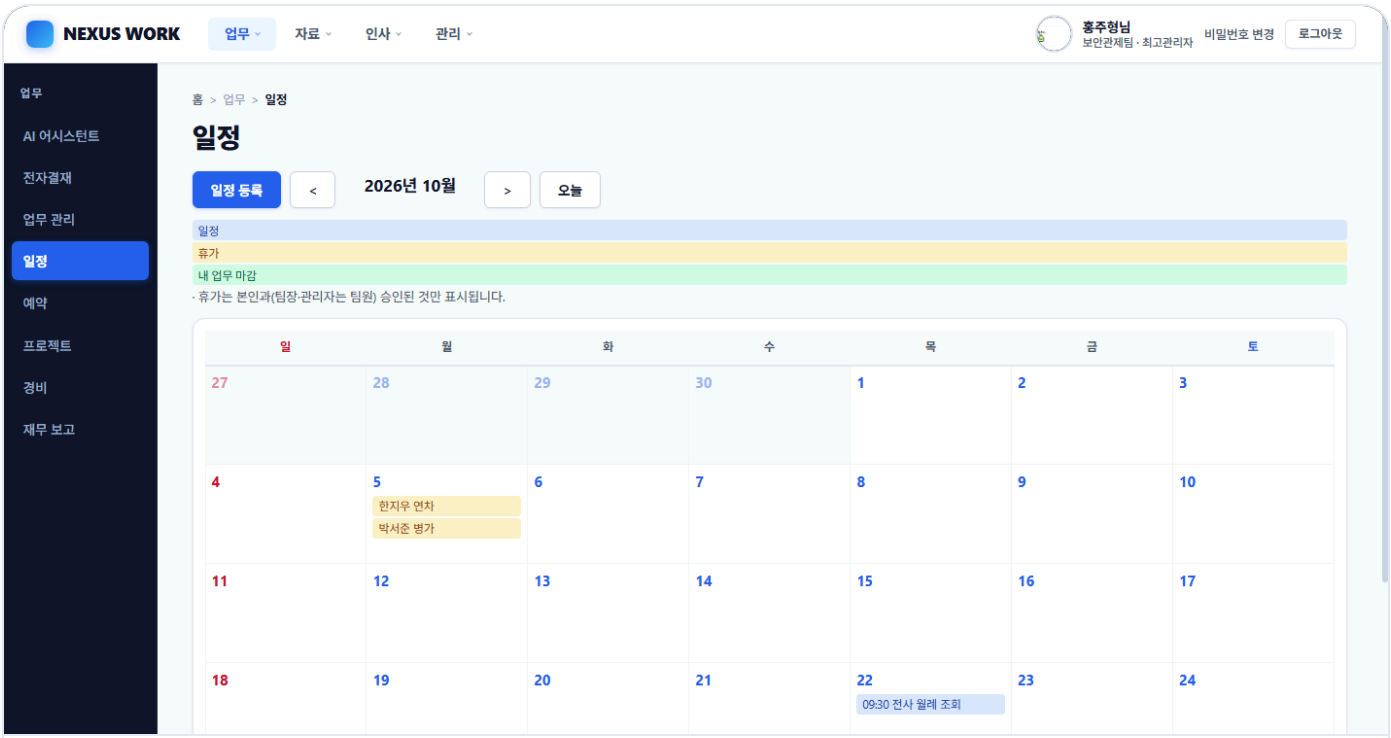
인사관리 및 동적 조직도 — Okta 스타일 IAM 사용자 디렉토리, 부서별 트리 뷰, 직급 및 역할 현황, 최소권한 기반 인사카드 수정.



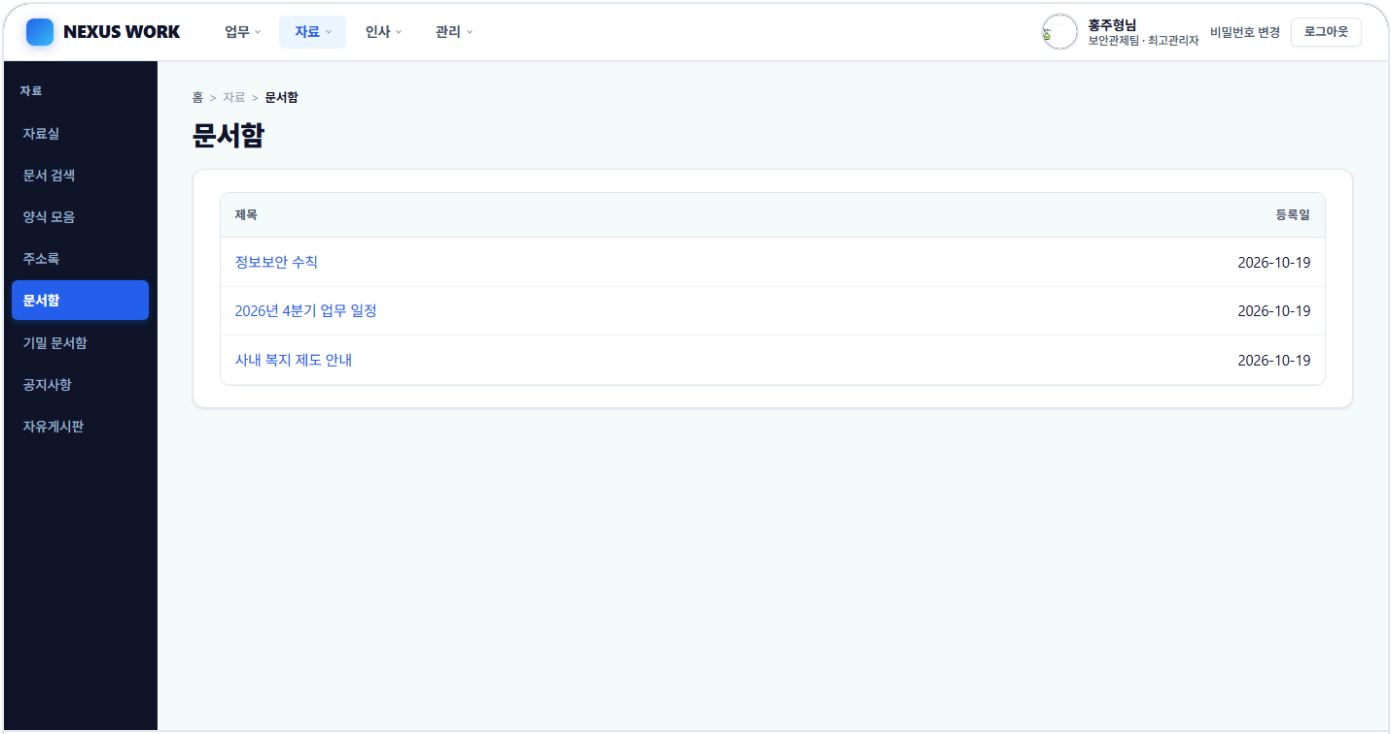
인사카드 관리 및 열람 통제 — 부서/직급별 상세 인사 정보, 최소권한 원칙(PoLP)에 기반한 직무 수정 권한 통제 및 감사 로그 기록.



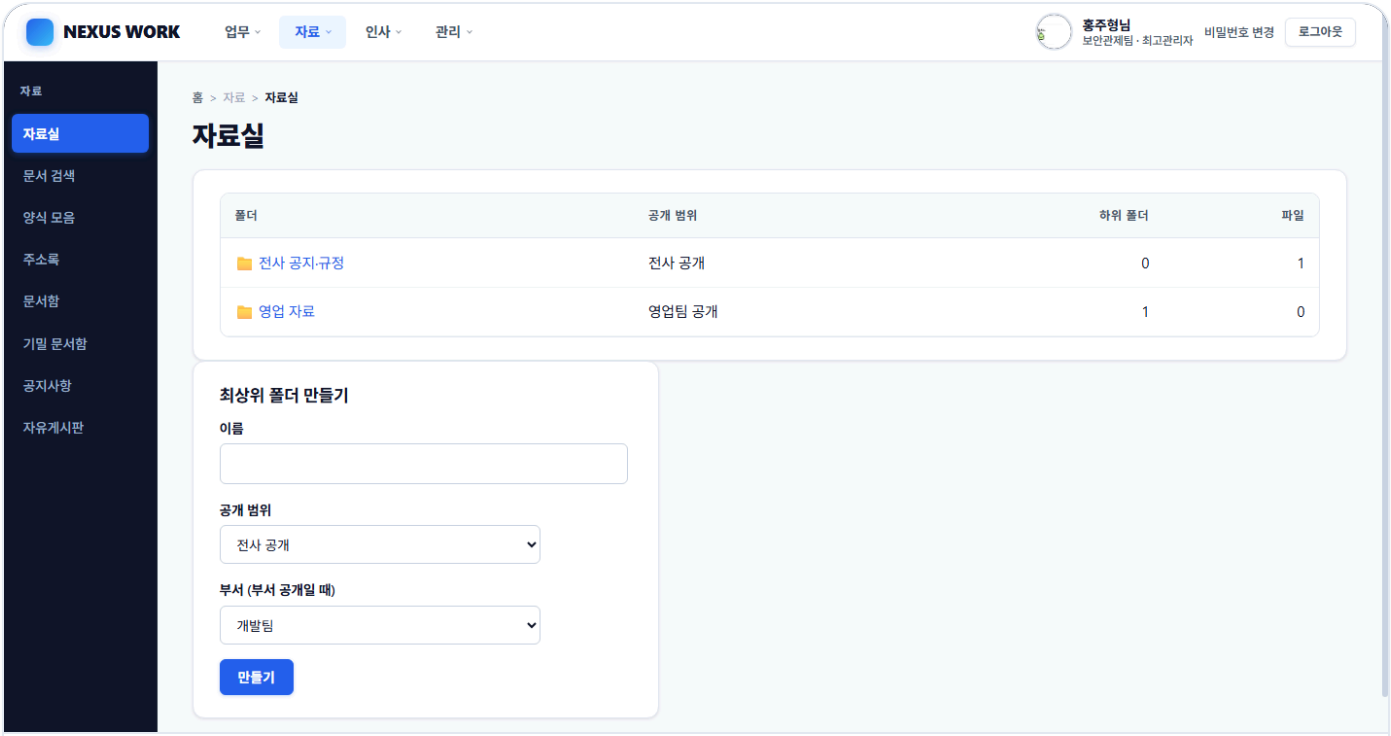
협업 업무 관리 — 칸반 보드 및 목록 뷰. 담당자 지정, 마감일, 우선순위 설정, 워크플로 상태 전이 및 댓글 소통 기능.



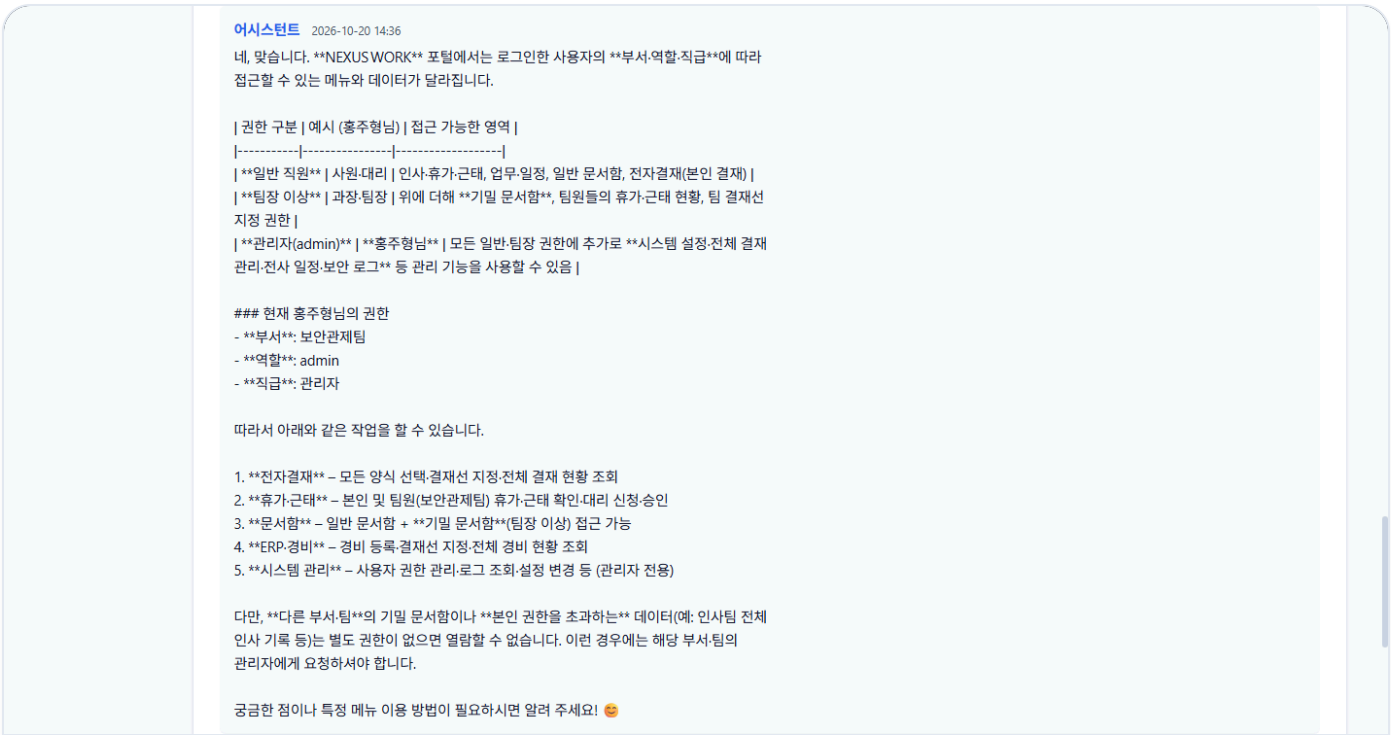
전사·부서 공유 캘린더 — 공개 범위(개인/팀/전사) 제어, 부서원 휴가 일정 및 프로젝트 마감일 실시간 연동.



사내 게시판 & 공지사항 — 리치 텍스트 에디터, 파일 업로드 시 UUID 변조 및 웹루트 외부 격리 저장으로 파일 취약점 차단.



보안 자료실 — 카테고리별 폴더형 구조, 파일 버전 관리 이력, 열람 권한 격리 및 통합 문서 검색.

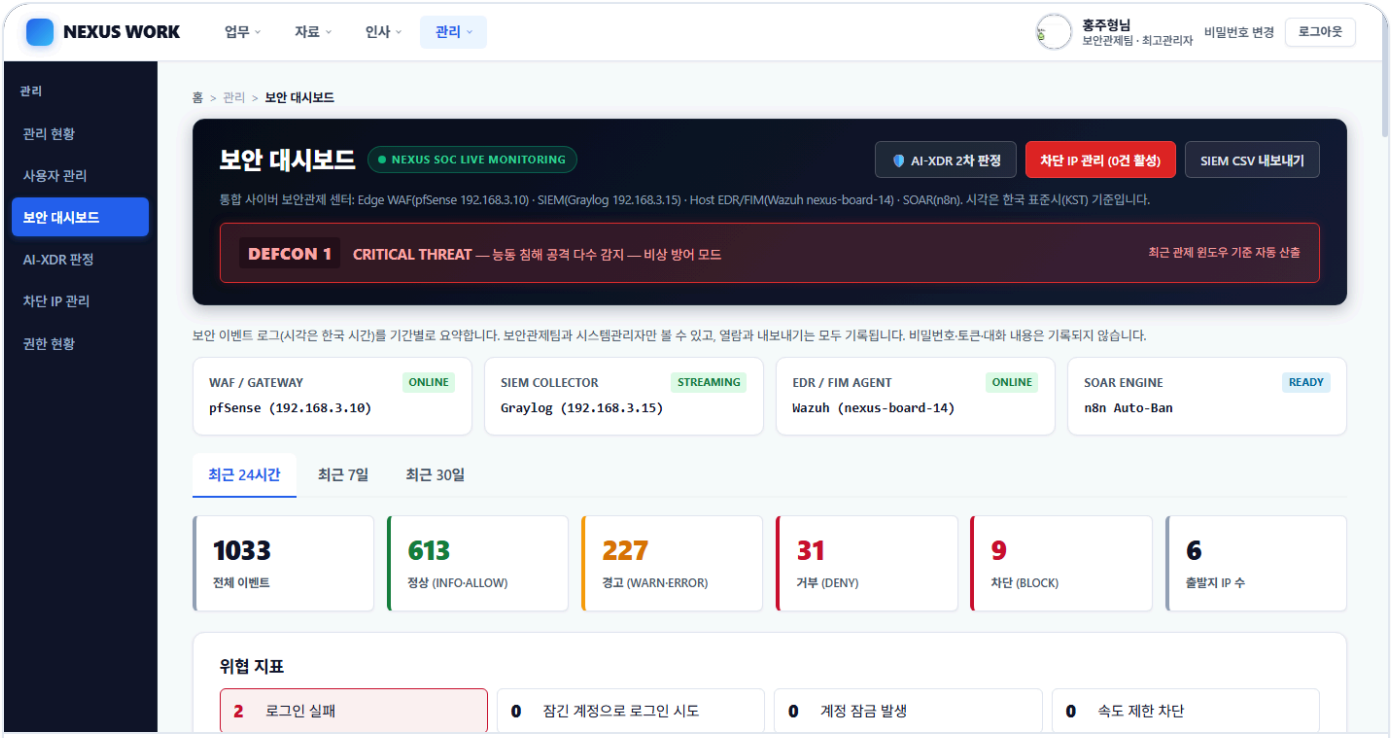


[사내 RAG AI 어시스턴트] — 사용자의 권한 범위를 벗어나지 않는 사내 규정 및 매뉴얼 데이터를 검색하여 답변합니다. NeMo Guardrails와 연동되어 시스템 프롬프트 탈옥, 직접/간접 인젝션 시도를 실시간 탐지하고 차단 로그를 기록합니다.

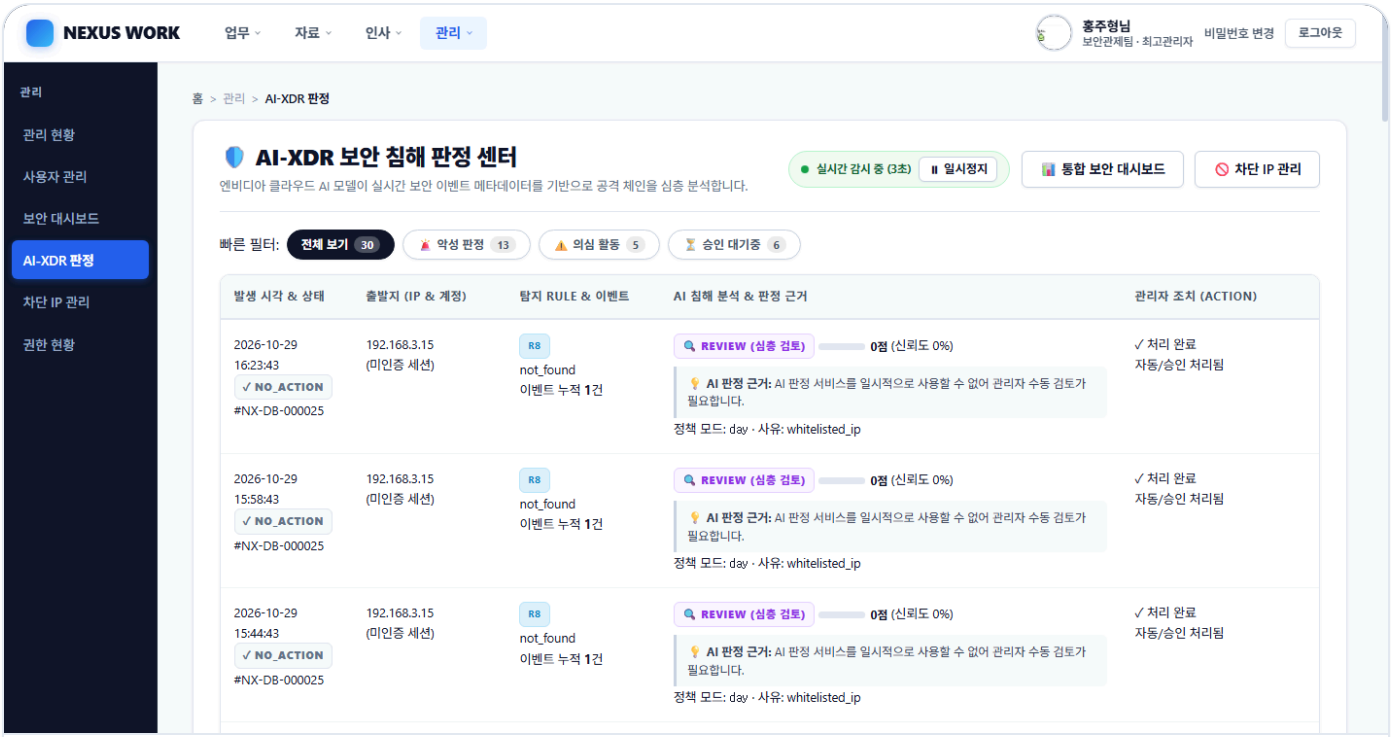
06 실시간 SOC 사이버 방어 콘솔 & AI-XDR 관제

탐지에서 즉각 대응까지

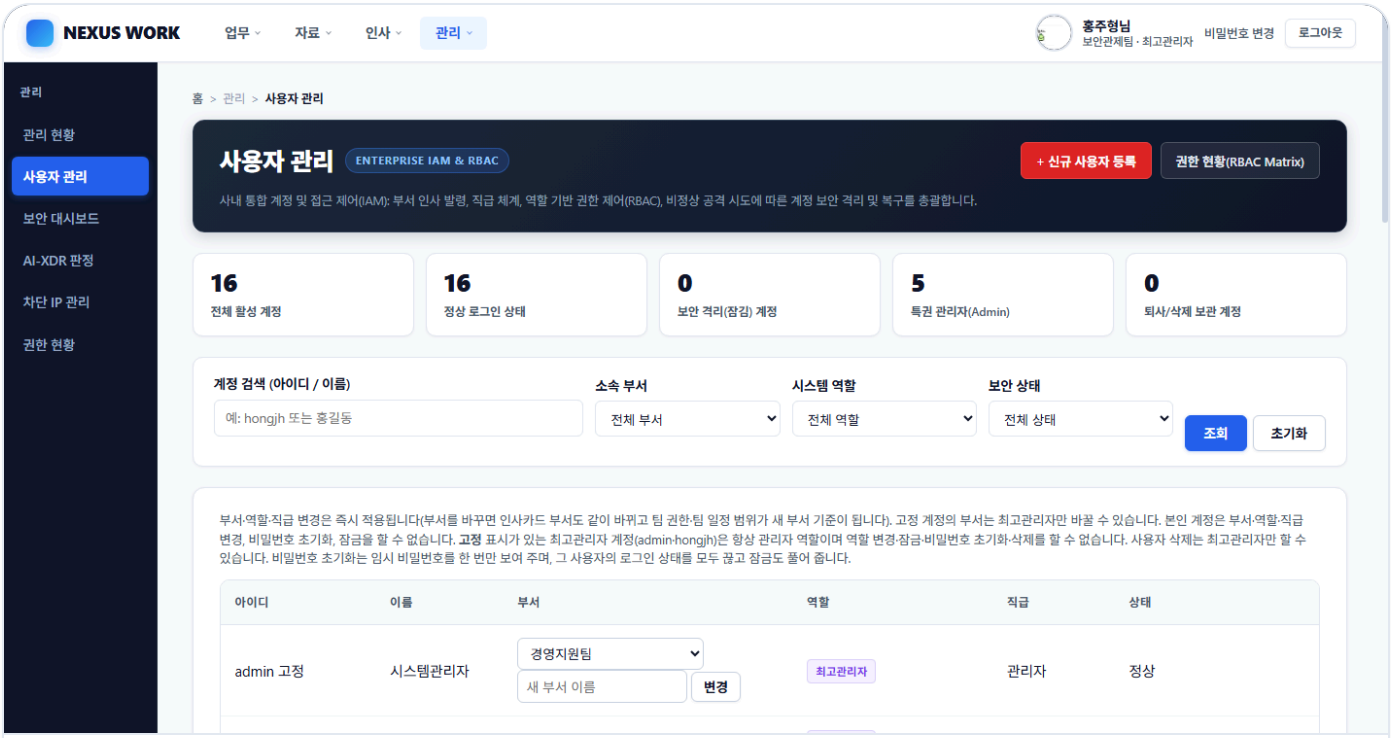
보안 전문 관제 기업(SOC/SIEM/SOAR) 수준의 전문성을 갖춘 관제 콘솔을 구축했습니다. R1~R12 탐지 룰과 Wazuh/Graylog/n8n/AI가 유기적으로 맞물려 실시간 공격을 격리합니다.



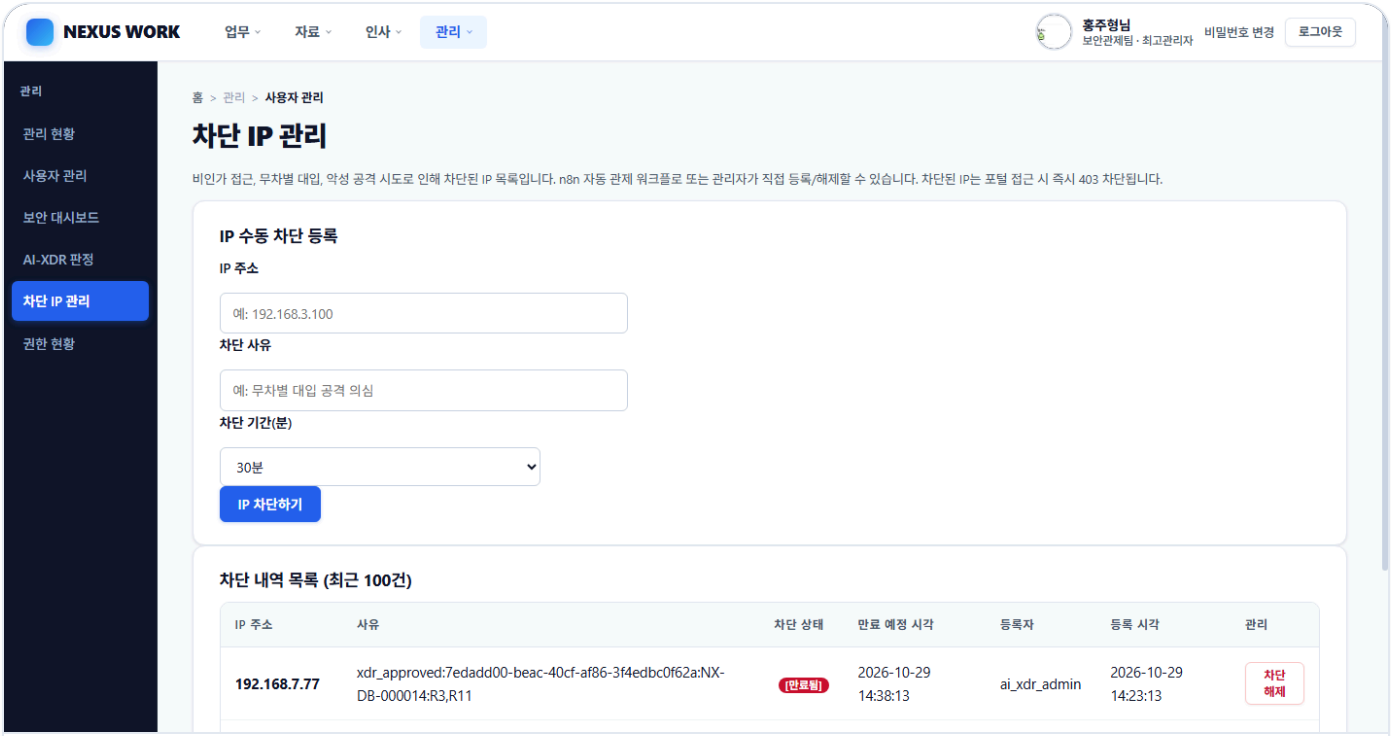
[SOC 사이버 방어 콘솔] — 실시간 위협 지수(DEFCON 1~5 자동 산정), 4대 파이프라인(Wazuh, Graylog, pfSense, n8n) 실시간 연결 상태, 침해 탐지 레이더 및 1클릭 비상 격리 지원.



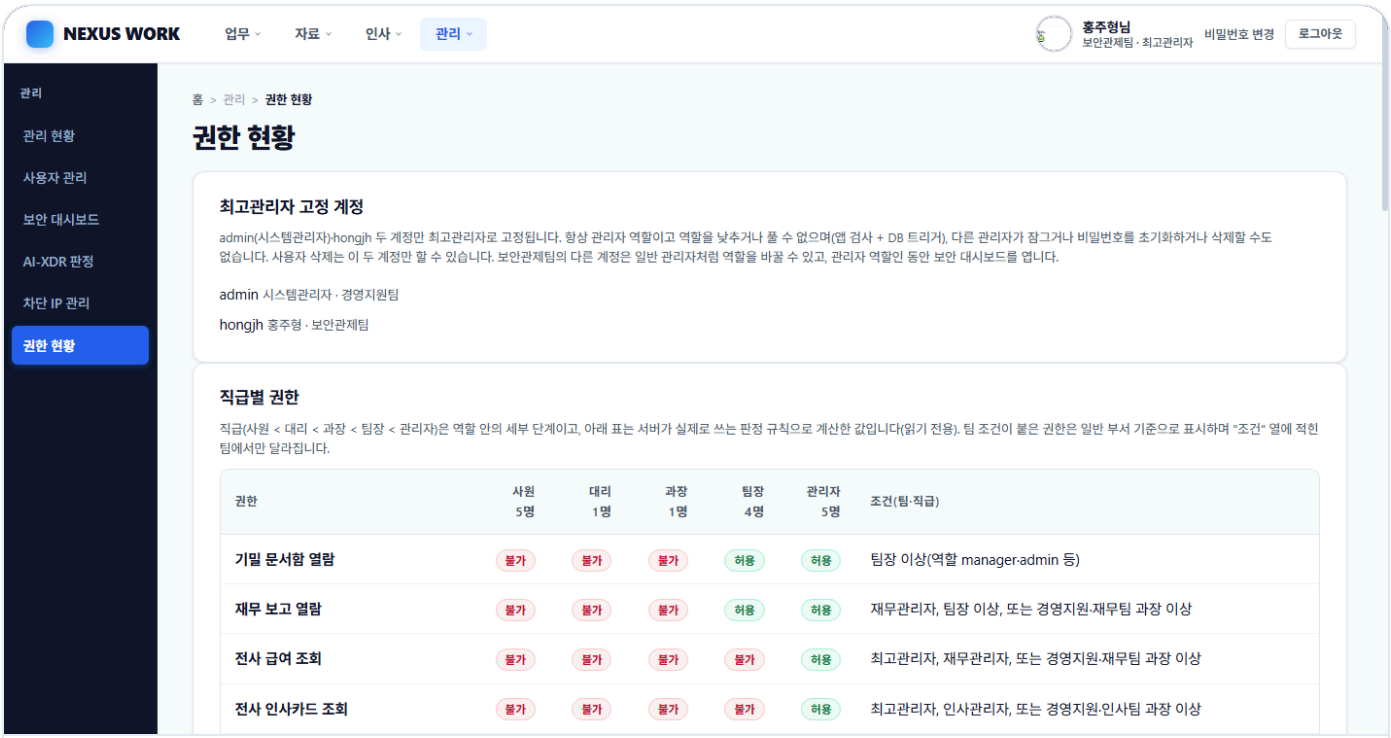
[AI-XDR 심층 판정 콘솔] — 규칙 기반 1차 탐지 이벤트를 NVIDIA 70B 모델이 심층 평가(위협 점수, 신뢰도, 근거 분석). 정책 모드(Dry-run / Semi-auto / Autonomous)에 따른 승인 및 자동 차단 연동.



[엔터프라이즈 IAM 사용자 관리 디렉토리] — Okta / Entra ID 스타일의 5대 핵심 KPI(전체 계정, 정상 활성, 최고관리자, 접근 잠금, 최근 로그인), 실시간 검색 및 부서/역할/상태별 정밀 필터링 디렉토리.



차단 IP 관리 콘솔 — 인메모리 3초 캐시로 초고속 차단 대조. 내부 관리망 및 서버 주소는 보호 목록(Whitelist)으로 지정되어 오차단 방지.

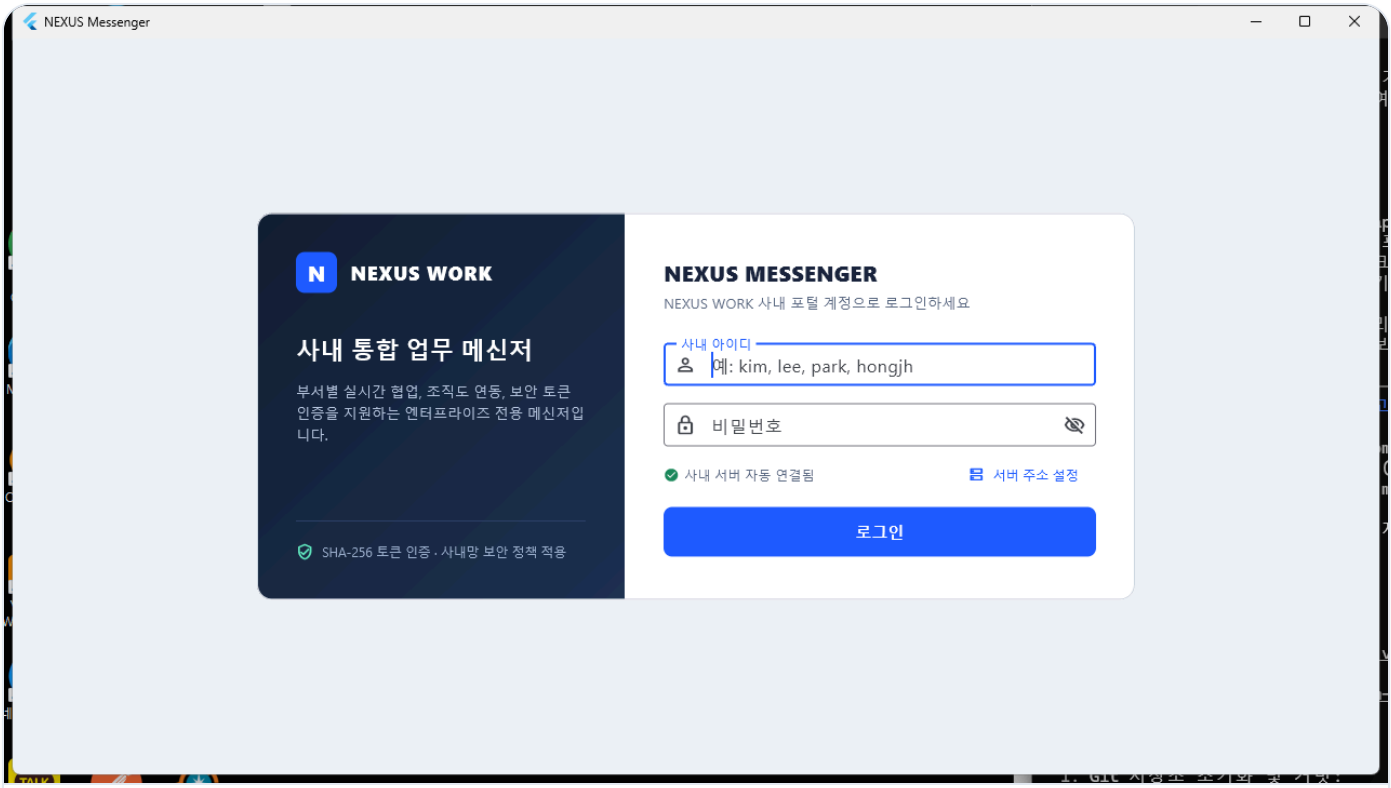


IAM 권한 현황 매트릭스 — 6대 직무별 권한 매트릭스, 팀 계정 접근 범위, 부서별 고정 관리자 보호 정책 한눈에 파악.

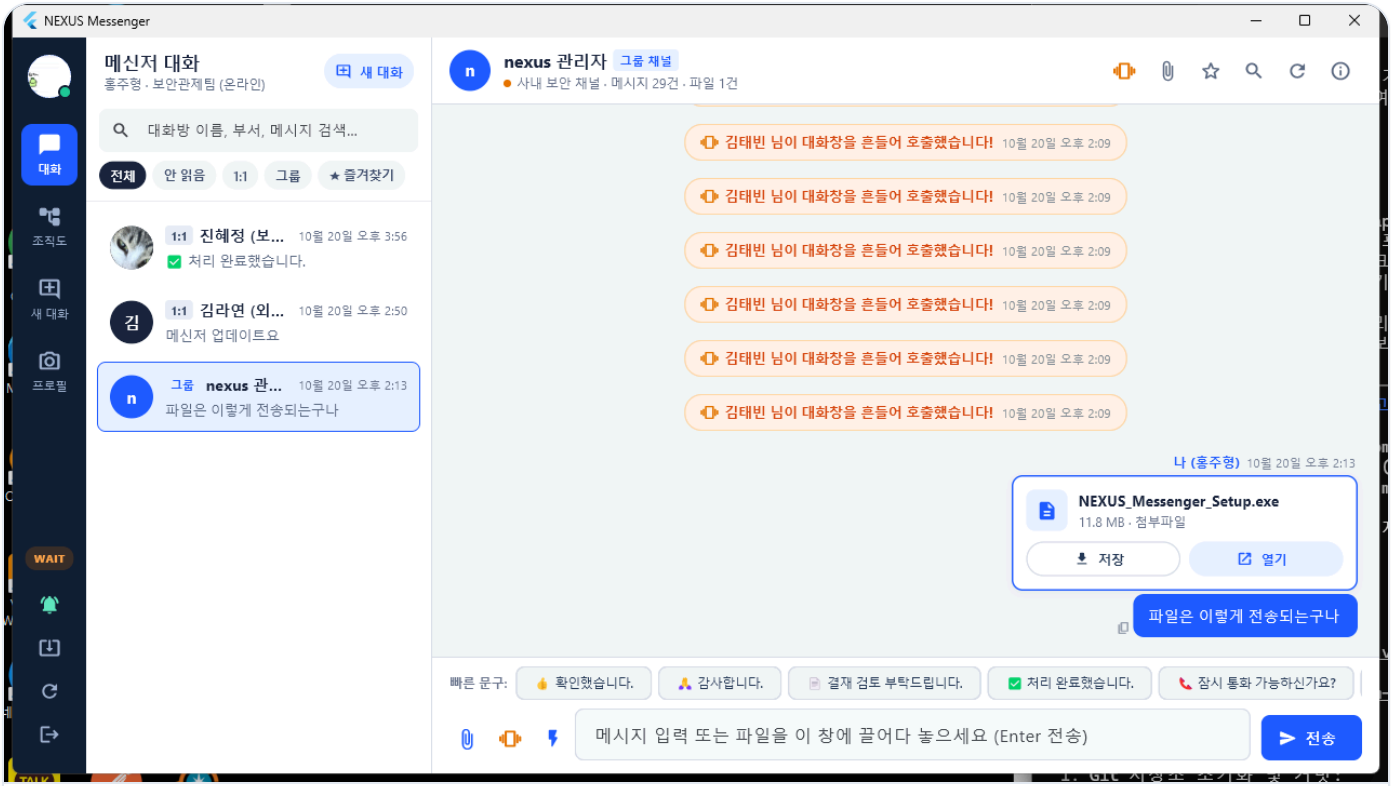
07 NEXUS Messenger

Flutter 기반 네이티브 데스크톱 앱

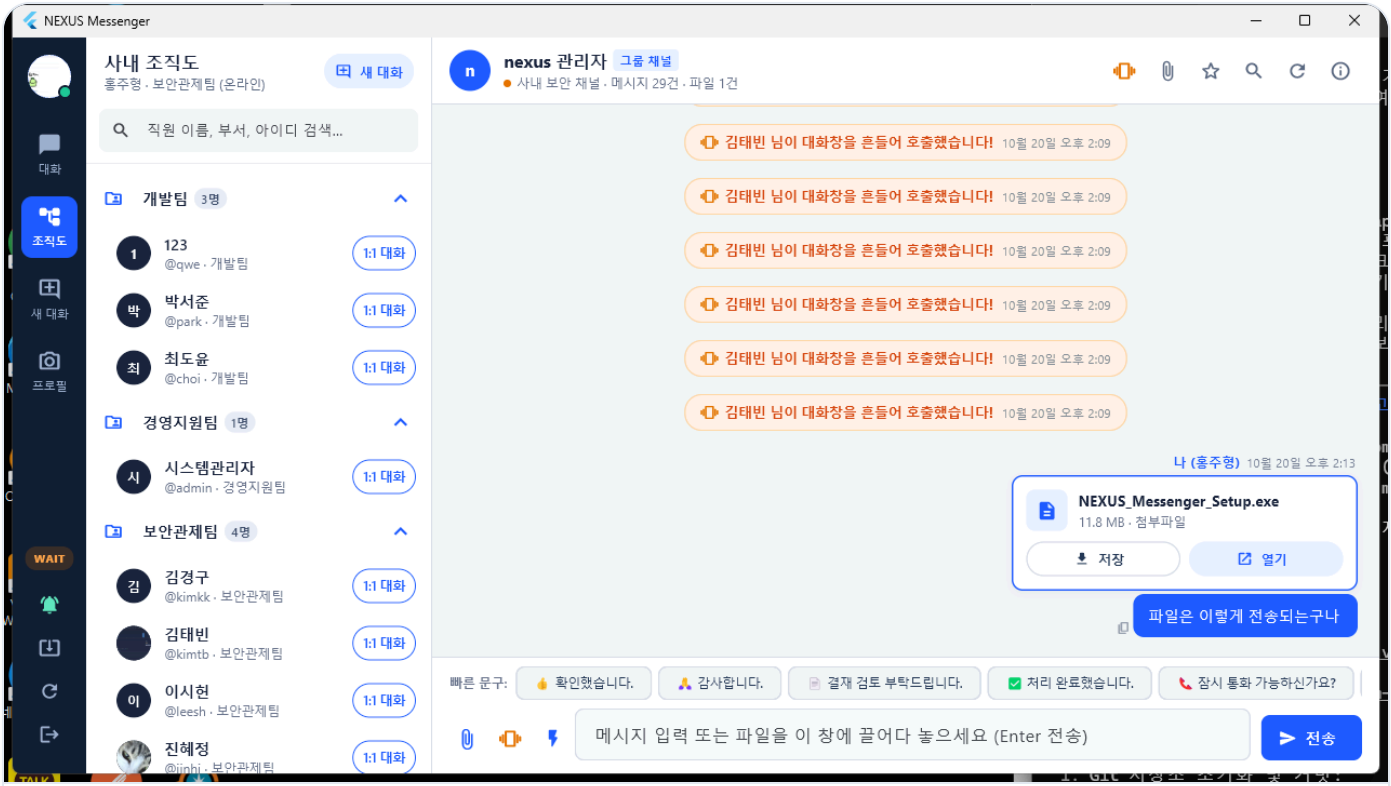
포털과 완벽히 동일한 사용자 계정 체계를 공유하는 크로스 플랫폼 데스크톱 사내 메신저입니다. 브라우저 외부에서도 실시간 업무 소통과 긴급 보안 알림을 수신할 수 있도록 제작되었습니다.



로그인 화면 — 사내 서버 자동 감지, SHA-256 토큰 발급, 포털 잠금 정책 연동.



실시간 대화 — Socket.IO 기반 1:1/그룹 채팅, 파일 전송, 윈도우 창 흔들기 호출.



사내 조직도 연동 — 부서별 재직 사원 검색 및 1클릭 대화방 개설.

구분	보안 및 아키텍처 구현 내용
토큰 인증	쿠키 대신 **SHA-256 해시로 저장되는 30일 만료 토큰**을 사용하여 웹과 동일한 `authenticate()` 로직 재사용(무차별 대입 방어 및 계정 잠금 완벽 동기화). 로그아웃 시 즉시 DB에서 무효화
CSRF 제외	쿠키가 아닌 `Authorization: Bearer` 방식을 사용하므로 `/api/v1/*` 경로는 구조적으로 CSRF 공격이 불가능하여 정교하게 분리
배포 보안	클라이언트 설치 및 자동 업데이트 시 `update_verifier` 해시 검증을 거쳐 변조된 실행 파일 배포 차단

08 주요 트러블슈팅 & 문제 해결 사례

실전 디버깅으로 입증된 역량

🚨 **Case 1.** `/ai-xdr/process` **호출 시** `processed=0` **침묵 실패 문제**

- **현상:** n8n에서 이벤트를 포털로 정상 전송(HTTP 202)했음에도 AI-XDR 판정 처리 건수가 계속 0건으로 기록됨.
- **원인 추적:** 관제 이벤트가 참조하는 외부 티켓 ID가 포털 로컬 DB에 존재하지 않아 외래키(Foreign Key) 위반이 발생했고, 쿼리에 사용된 `INSERT IGNORE` 옵션으로 인해 에러 로그 없이 조용히 롤백되고 있었음.
- **해결:** 로컬 DB에 존재하는 티켓만 참조하도록 검증 로직을 추가하고, 외부 티켓 정보는 JSON 페이로드에 안전하게 보존하도록 수정. 상세 디버그 로그(`xdr_process_debug`)를 구축하여 단계별 추적 보장.
- **교훈:** 오류를 숨기는 SQL 옵션(`IGNORE`)은 반드시 영향 받은 행 수(`rowcount`)를 검증해야 합니다.

🚨 Case 2. 관리자 화면에서 수동 IP 차단 시 HTTP 500 서버 에러 발생

- **현상:** SOC 관리자 화면에서 악성 IP 차단 버튼을 클릭했을 때 간헐적으로 500 내부 서버 오류 발생.
- **원인 추적:** `admin.py` 내에서 `log_event()` 호출 시 키워드 인자(`ip`) 중복 전달 및 모듈 임포트 누락 확인.
- **해결:** `admin.py`의 파라미터 전달 체계를 정규화하고 핫픽스 적용. 회귀 테스트 슈트에 수동 차단 검증 케이스를 추가하여 재발 방지.

🚨 Case 3. Waitress 스레드 풀 고갈에 의한 서비스 지연 (2026-10-29 패치)

- **현상:** SSE 실시간 감사 스트림(`/admin/audit/stream`) 접속자가 늘어날 경우 다른 모든 웹 요청이 타임아웃 발생.
- **원인 추적:** Waitress WSGI 서버의 작업자 스레드가 16개로 고정된 상태에서, SSE 연결이 스레드를 장시간 점유함.
- **해결:** 계정당 동시 스트림 3개 상한(`AUDIT_STREAM_MAX_CONCURRENT=3`), IP별 초당 개설 속도 제한, 600초 최대 수명 주기(`AUDIT_STREAM_MAX_SECONDS=600s`)의 3중 방어막을 구축하여 스레드 고갈 DoS 원천 방어.

09 팀 협업 & 프로젝트 회고

체계적인 인터페이스 계약과 성장

1. 역할 분담 및 인터페이스 표준화

- **홍주형 (본인):** 포털 웹·DB 아키텍처 구축, 전체 엔드포인트 심층 하드닝, IAM 6대 권한 설계, AI-XDR 파이프라인 수신단 구축, 취약점 패치
- **김태빈:** 중앙 관제 서버(192.168.3.15) 구축, Wazuh 매니저/Graylog SIEM/n8n SOAR 룰셋(R1~R12) 수립 및 자동화 워크플로 개발
- **이시헌:** 경계망 방화벽(192.168.3.10) pfSense 구축, HAProxy WAF 규칙 설정, 네트워크 트래픽 통제

- **진혜정:** 가상화 시스템 및 인프라 운영 관리
- **인터페이스 계약:** 관제와 웹 포털 간의 통신 규격을 docs/03_팀_연동안내.md 문서로 명확히 정의하고, /internal/api/v1/* API 규격을 사전 합의하여 병목 없는 애자일 개발을 진행했습니다.

2. 회고 및 향후 발전 방향

- **배운 점:** 보안은 단순히 기능을 막는 것이 아니라, "업무의 연속성을 보장하면서도 공격자가 악용할 수 있는 틈을 구조적으로 차단하는 엔지니어링"임을 깨달았습니다. 특히 Cloudflare의 적대적 서브에이전트 검증 방식을 통해 오탐 없는 코드 감사의 중요성을 체득했습니다.
- **향후 개선 계획:**
  ① 전사 HTTPS(TLS 종료 및 쿠키 Secure 속성) 전면 적용
  ② AI-XDR 실시간 격리 모드의 점진적 live 확대
  ③ 오픈소스 서드파티 의존성 패키지(SBOM) 자동 스캔 파이프라인 연동

※ 본 포트폴리오의 모든 데이터는 교육 및 검증용 가상 시나리오 데이터입니다. 화면 캡처는 2026-10-28~2026-10-29 로컬 및 분산 테스트베드 환경에서 직접 촬영되었습니다.